

RESEARCH PROJECT PROPOSAL

On-Chain Threat Intelligence Oracle: A Decentralised Framework for Bridging Web2 Attack Surface Monitoring with Web3 Infrastructure Security

Student Name:	James Kabingu Mbugua
Registration Number:	[Registration Number]
Supervisor:	[Supervisor Name]
Department:	Computer and Information Science
School:	School of Pure and Applied Sciences (SPAS)
Academic Year:	2025 / 2026
Date:	May 2026

Abstract

The decentralised finance (DeFi) ecosystem has experienced unprecedented growth alongside an equally unprecedented rise in security incidents. Industry analysis consistently indicates that approximately 80% of funds stolen from Web3 projects originate not from smart contract exploits but from attacks on surrounding Web2 infrastructure -- domain name system (DNS) hijacking, frontend supply chain compromise, phishing campaigns, and cloud misconfiguration. Despite this, no decentralised, incentivised, and immutable threat intelligence infrastructure exists to address this attack surface at the protocol level.

This research proposes the design, implementation, and evaluation of an On-Chain Threat Intelligence Oracle -- a decentralised framework that monitors Web2 attack indicators in real time, stores verified threat intelligence immutably on a public blockchain, and exposes a native query interface that Web3 protocols can call before executing sensitive operations. The system incorporates a token-based reputation and incentive mechanism to govern the quality and integrity of submitted intelligence, creating an economically sustainable threat intelligence network.

The project contributes a novel architecture at the intersection of cybersecurity, blockchain technology, and decentralised governance -- directly addressing the most prevalent and

underserved attack surface in the Web3 ecosystem.

1. Introduction

The global foreign exchange market processes approximately 7.5 trillion USD per day. Blockchain-based financial protocols -- commonly referred to as decentralised finance or DeFi -- have grown to hold tens of billions of dollars in total value locked (TVL) across various chains. This intersection of traditional finance and decentralised infrastructure represents one of the most significant technological developments of the current decade, and one of the most actively targeted by adversaries.

The security community has invested significant effort in smart contract auditing -- the review of Solidity code for on-chain vulnerabilities. However, the dominant attack vector remains consistently overlooked in academic and industry literature: the Web2 infrastructure layer surrounding Web3 systems. DNS hijacking, phishing attacks against developers, frontend repository compromise via supply chain attacks, credential exposure through cloud misconfiguration, and BGP routing attacks account for the majority of documented losses in the DeFi ecosystem.

Existing threat intelligence solutions -- platforms such as VirusTotal, Shodan, and AlienVault OTX -- are centralised, permissioned, and inaccessible to smart contracts at runtime. A DeFi protocol executing a transaction or serving a frontend cannot natively query whether the counterparty address has been flagged, whether the serving domain has been hijacked, or whether the frontend pipeline has been compromised. This gap between off-chain threat intelligence and on-chain protocol execution represents a fundamental and unaddressed security problem.

This research proposes to close this gap through the design and implementation of a decentralised threat intelligence oracle that bridges Web2 monitoring with Web3 infrastructure, making real-time threat context natively available to smart contracts and DeFi protocols.

1.1 Background and Motivation

The 2022 Ronin Network hack -- resulting in 625 million USD in losses -- was initiated through a phishing attack on a developer, not a smart contract exploit. The 2023 Ledger Connect Kit supply chain attack compromised dozens of DeFi frontends through a single poisoned npm package. The 2022 Curve Finance DNS hijack redirected legitimate user traffic to a malicious server for hours before detection. In each case, the smart contracts functioned exactly as designed. The failure was at the Web2 infrastructure layer.

These incidents share a common characteristic: the attack indicators -- malicious domains, suspicious certificate issuance, anomalous DNS changes, compromised package versions -- were observable before significant losses occurred. The problem is not the absence of signals but the absence of infrastructure to collect, verify, and distribute those signals to the systems that need them most.

1.2 Problem Statement

Web3 protocols currently lack access to real-time, verifiable threat intelligence at the point of execution. Existing threat intelligence infrastructure is centralised, permissioned, and architecturally incompatible with decentralised systems. This creates a persistent vulnerability: protocols cannot programmatically check threat context before executing transactions, serving content, or interacting with external systems. The result is that well-audited smart contracts continue to be exploited through their surrounding infrastructure.

2. Research Objectives

This research aims to achieve the following objectives:

1. Design a decentralised architecture for collecting, validating, and storing Web2 threat indicators on-chain.
2. Implement smart contracts governing the submission, validation, and incentive mechanisms of the threat intelligence network.
3. Develop a Chainlink-compatible oracle interface exposing on-chain threat data to querying protocols.
4. Build a Web2 monitoring layer detecting DNS changes, certificate transparency anomalies, phishing indicators, and supply chain compromise signals.
5. Evaluate the system's effectiveness by correlating its threat indicator database against documented real-world incidents.
6. Assess the economic viability of the token-based incentive model for sustaining decentralised threat intelligence contribution.

3. Research Questions

The research is guided by the following questions:

1. Can a decentralised threat intelligence oracle provide actionable Web2 attack surface indicators to Web3 protocols at runtime?
2. What governance and incentive mechanisms best ensure the quality and integrity of submitted threat intelligence in a permissionless network?
3. To what degree does on-chain threat intelligence coverage correlate with documented Web2 attack vectors against Web3 projects?
4. What is the performance and cost overhead of on-chain threat intelligence queries for DeFi protocols operating at scale?

4. Significance of the Study

This research makes contributions across three domains. In the academic domain, it presents the first formal architecture for decentralised, incentivised threat intelligence as a native Web3 primitive. In the technical domain, it produces a working implementation that DeFi protocols can

integrate to reduce their Web2 attack exposure. In the economic domain, it models a sustainable token incentive structure for security-critical public goods -- a category of blockchain application that remains significantly underexplored.

The practical impact is measurable: if protocols querying the oracle before executing transactions or serving frontends can detect and respond to even a fraction of the Web2 indicators preceding documented attacks, the reduction in losses would represent significant real-world value. Given that documented Web2-origin losses in the DeFi ecosystem exceed 5 billion USD over the past four years, even marginal improvement in detection capability represents substantial impact.

5. Literature Review

5.1 Web2 Attack Vectors on Web3 Infrastructure

The academic literature on DeFi security has focused predominantly on smart contract vulnerabilities -- reentrancy, flash loan exploits, oracle manipulation, and access control failures (Atzei et al., 2017; Zhou et al., 2023). The Web2 attack surface has received comparatively limited formal treatment despite its dominance in incident data. Chainalysis (2023) reported that infrastructure-level attacks -- phishing, supply chain compromise, and DNS manipulation -- accounted for the majority of DeFi losses by value. Perez and Livshits (2021) documented that a significant proportion of exploited contracts had been formally audited, suggesting that contract-level security is insufficient without infrastructure-level protections.

5.2 Threat Intelligence Systems

Traditional threat intelligence platforms operate as centralised repositories. The Structured Threat Information eXpression (STIX) and Trusted Automated eXchange of Intelligence Information (TAXII) standards define formats and protocols for sharing threat data, but these were designed for enterprise security operations centres rather than decentralised protocol execution environments (Barnum, 2012). The OpenIOC format and MISP platform represent the state of the art in collaborative threat intelligence but share the same centralisation assumptions.

5.3 Blockchain Oracles

The oracle problem -- the challenge of bringing trustworthy off-chain data onto a blockchain -- has been extensively studied. Chainlink's decentralised oracle network (Breidenbach et al., 2021) represents the dominant practical solution, using a network of independent node operators and cryptographic aggregation to provide tamper-resistant price feeds and external data. Town Crier (Zhang et al., 2016) proposed trusted execution environments (TEEs) as an alternative oracle mechanism. This research builds on these foundations to extend oracle architecture to a new domain: real-time security threat data.

5.4 Decentralised Governance and Token Economics

Token-based governance and incentive mechanisms have been studied extensively in the context of decentralised autonomous organisations (DAOs) and decentralised finance (Buterin, 2014; Jensen et al., 2021). Reputation systems for decentralised networks have been explored in the context of peer-to-peer systems (Xiong and Liu, 2004). This research synthesises these bodies of work to design an incentive mechanism specifically suited to security-critical information -- where false submissions carry systemic risk and quality verification is non-trivial.

5.5 Research Gap

No existing research addresses the integration of real-time Web2 threat monitoring with on-chain data storage and native oracle query interfaces for Web3 protocol consumption. This gap represents the precise contribution of the proposed research.

6. Research Methodology

This research adopts a design science research (DSR) methodology (Hevner et al., 2004), combining system design, implementation, and empirical evaluation. The research proceeds through four phases:

6.1 Phase 1: Architecture Design

The system architecture will be formally specified across four components: the Web2 monitoring layer, the on-chain storage and governance contracts, the oracle interface, and the query dashboard. Architecture decisions will be documented with justification for technology selection, trade-off analysis, and security model specification. The architecture will be reviewed against existing oracle systems and threat intelligence standards.

6.2 Phase 2: Implementation

The implementation phase produces four working components:

Web2 Monitoring Layer: Python-based monitoring scripts will poll Certificate Transparency logs, DNS record change feeds, known phishing URL databases, and public npm audit feeds. Detected indicators will be structured according to a defined schema and submitted to the on-chain layer.

Smart Contract Layer: Solidity contracts deployed on Ethereum Sepolia testnet will implement indicator submission, multi-party validation, stake-based reputation scoring, reward distribution, and the public query interface. Contracts will be developed using the Foundry framework and audited using Slither static analysis.

Oracle Interface: A Chainlink-compatible oracle adapter will expose the on-chain threat database to external protocol queries, supporting domain hash lookups, address reputation checks, and certificate anomaly flags.

Dashboard: A React-based web interface will display live threat indicators, researcher reputation scores, protocol query activity, and correlation visualisations linking indicator spikes to documented incidents.

6.3 Phase 3: Evaluation

The system will be evaluated against three criteria. Coverage evaluation will measure what proportion of documented Web2 attack indicators from 2022 to 2024 incidents would have been detectable by the monitoring layer. Timeliness evaluation will measure the lag between real-world indicator emergence and on-chain availability. Economic evaluation will model the sustainability of the token incentive mechanism under varying participation assumptions using agent-based simulation.

6.4 Phase 4: Documentation and Publication

All system components will be released as open source under the MIT licence. A technical whitepaper will document the architecture and economic model. Academic findings will be submitted for conference publication.

7. Proposed System Architecture

The On-Chain Threat Intelligence Oracle operates as a four-layer system:

Layer	Component	Technology
1. Monitoring	Web2 attack surface scanner	Python, Certstream, DNS APIs
2. Storage	On-chain indicator registry	Solidity, Ethereum / L2
3. Oracle	Query interface for protocols	Chainlink adapter, Solidity
4. Interface	Public dashboard	React, Web3.js, Python backend

The monitoring layer continuously scans public data sources for threat indicators. Validated indicators are submitted to the smart contract registry by participating researchers who stake tokens as a quality guarantee. The oracle adapter exposes a query function that DeFi protocols can call synchronously before executing sensitive operations. The dashboard aggregates all on-chain activity into a publicly accessible interface.

8. Project Timeline

Phase	Activity	Duration	Deliverable
1	Literature review and architecture design	Weeks 1-4	Architecture specification document
2	Web2 monitoring layer implementation	Weeks 5-8	Working monitoring scripts
3	Smart contract development and testing	Weeks 9-13	Deployed and tested contracts
4	Oracle interface and dashboard	Weeks 14-17	Live system on testnet
5	Evaluation and analysis	Weeks 18-20	Evaluation report

6	Documentation and write-up	Weeks 21-24	Final project report
---	----------------------------	-------------	----------------------

9. Resources Required

9.1 Software and Development Tools

- Foundry -- Solidity development and testing framework
- Python 3.x -- monitoring layer and evaluation scripts
- React -- dashboard frontend
- Chainlink node -- oracle adapter development
- Slither -- smart contract static analysis
- Ethereum Sepolia testnet -- contract deployment and testing

9.2 Data Sources

- Certstream -- real-time Certificate Transparency log feed (free)
- SecurityTrails / PassiveDNS -- DNS change monitoring API
- OpenPhish / PhishTank -- phishing URL feeds (free)
- npm audit API -- package vulnerability feed (free)
- Alchemy / Infura -- Ethereum node access (free tier)

9.3 Estimated Budget

Item	Estimated Cost
Cloud compute for monitoring layer (6 months)	USD 0 -- student free tiers
Sepolia testnet ETH for gas	USD 0 -- faucets
API access (SecurityTrails student plan)	USD 0 -- free academic tier
Domain for live dashboard	USD 12 -- annual
Total	USD 12

10. Ethical Considerations

All threat intelligence data collected will be sourced from public feeds and publicly observable network infrastructure. No private user data, personally identifiable information, or non-public systems will be monitored or accessed. The research will comply with Kenyatta University's ethical research guidelines and applicable data protection regulations.

The system is designed as a defensive tool. All code will be released under an open source licence to ensure transparency of implementation and prevent misuse. The token incentive mechanism will include explicit governance provisions against the submission of false or manipulated threat intelligence.

11. Expected Outcomes and Contributions

This research is expected to produce the following outputs:

1. A formal architecture specification for decentralised threat intelligence oracles.
2. A working open-source implementation deployed on Ethereum testnet.
3. An empirical evaluation of system coverage against documented Web2 attack incidents.
4. A technical whitepaper suitable for industry and academic publication.
5. A public dashboard providing live threat intelligence visibility to the Web3 community.

The primary academic contribution is the first formal treatment of decentralised, on-chain threat intelligence as a security primitive for Web3 protocols. The primary practical contribution is a deployable system that reduces the gap between observable Web2 attack indicators and protocol-level security response.

References

- Atzei, N., Bartoletti, M., and Cimoli, T. (2017). A survey of attacks on Ethereum smart contracts. *Principles of Security and Trust*, 10204, 164-186.
- Barnum, S. (2012). Standardizing cyber threat intelligence information with the Structured Threat Information eXpression (STIX). MITRE Corporation.
- Breidenbach, L., Cachin, C., Chan, B., Coventry, A., Ellis, S., Juels, A., and Nazarov, S. (2021). Chainlink 2.0: Next steps in the evolution of decentralised oracle networks. Chainlink Labs.
- Buterin, V. (2014). A next-generation smart contract and decentralised application platform. Ethereum Foundation.
- Chainalysis. (2023). The Chainalysis 2023 Crypto Crime Report. Chainalysis Inc.
- Hevner, A., March, S., Park, J., and Ram, S. (2004). Design science in information systems research. *MIS Quarterly*, 28(1), 75-105.
- Jensen, J., Pourali, H., and Mosakheil, J. (2021). Decentralised autonomous organisations: Governance and token economics. *Journal of Organization Design*.
- Perez, D. and Livshits, B. (2021). Smart contract vulnerabilities: Vulnerable does not mean exploited. 30th USENIX Security Symposium.
- Xiong, L. and Liu, L. (2004). PeerTrust: Supporting reputation-based trust for peer-to-peer electronic communities. *IEEE Transactions on Knowledge and Data Engineering*, 16(7), 843-857.
- Zhang, F., Cecchetti, E., Croman, K., Juels, A., and Shi, E. (2016). Town Crier: An authenticated data feed for smart contracts. CCS 2016.
- Zhou, L., Qin, K., and Gervais, A. (2023). SoK: Decentralised finance attacks. *IEEE Symposium on Security and Privacy*.

Declaration

I declare that this research proposal is my original work and has not been submitted for examination in any other university or institution. All sources have been acknowledged in accordance with academic integrity requirements.

Student Signature: _____

Name: James Kabingu Mbugua

Date: May 2026

Supervisor Signature: _____

Name: [Supervisor Name]

Date: _____